Requirements specification: FaceAttend EDU

Jonattan Steven Rizo Solano

Diego Andrés Gutiérrez Núñez

Juan David Arboleda Perdomo

Centro de la Industria, la Empresa y los Servicios, Servicio Nacional de Aprendizaje

Technologist in Software Analysis and Development, Cohort 3145556

Karol Daniela Correa

November 8, 2026

Abstract

This report specifies the functional requirements for the management system of users, academic environments, attendance control, mobile configurations, histories, justifications, advanced reports, and school management. Each requirement is documented with its purpose, platform, inputs, business rules, acceptance criteria, security considerations, edge cases, and verification mechanisms. Its goal is to serve as a contractual, technical, and audit basis for software development, testing, deployment, and maintenance.

Keywords: requirements specification, requirements engineering, educational software, attendance control, biometrics, IoT, RBAC, mobility

Contents

Introduction 5
Objective 5
Scope 5
Definitions 6
System Actors 7
Premises and Restrictions 8
Premises 8
Restrictions 8
Transversal Acceptance Criteria 8
Functional Requirements 9
RF 1 User Management 9
RF 2 Environment Management 16
RF 3 Entry and Exit Records 19
RF 4 System Configuration 22
RF 5 Generate Histories 26
RF 6 Justification Management 27
RF 7 Advanced Visualization and Reports 29
RF 8 School Management 31
Requirements Traceability Matrix 33
Derived Non-Functional Requirements 34
Identified Technical and Business Risks 35
Verification and Validation Plan 36
Static Verification 36
Unit Tests 36
Integration Tests 36
End-to-End Tests 36

Security Tests 37
Performance Tests 37
User Validation 37
Security and Privacy Considerations 37
Biometric Data 37
Authentication and Sessions 38
Import and Export 38
IoT 38
Annexes 38
Annex A. Minimum Operational Dictionary 38
Annex B. Recommended Minimum Structure for CSV Import 39
Annex C. Example of Minimum RBAC Matrix 39
Annex D. Suggested States for Justifications 40
Conclusions 40
References 41

Requirements specification: FaceAttend EDU

Introduction

The system described in this report supports the integral management of users, environments or classrooms, cohorts or courses, entry and exit records, mobile configurations, attendance histories, justifications, analytical reports, and the administration of the school's academic catalog. The functional requirements derive from the list provided by the product area and are detailed here as verifiable specifications, aligned with requirements engineering best practices (International Organization for Standardization, International Electrotechnical Commission, & Institute of Electrical and Electronics Engineers [ISO, IEC, & IEEE], 2018).

From a software quality perspective, each requirement must be unambiguous, complete, consistent, verifiable, and traceable. Therefore, this document does not limit itself to repeating RF and ERF identifiers, but defines input conditions, processing, output, business rules, permissions, audit events, acceptance criteria, and edge cases. This structure reduces ambiguity during development, facilitates automated testing, and supports internal or external audits.

The presentation follows hierarchical organization principles, author-date citation, and verifiable references, consistent with the seventh edition of the APA Standards (American Psychological Association [APA], 2020). In Markdown, visual fidelity of line spacing, margins, hanging indents, and typography must be guaranteed in the final export to `.docx` or `.pdf`.

Objective

To formally specify the functional requirements of the software, defining expected behavior, role responsibilities, security restrictions, acceptance criteria, and verification mechanisms for the modules of user management, environments, attendance, configuration, histories, justifications, reports, and school management.

Scope

This document applies to the development, testing, deployment, and maintenance of the administrative web platform and the associated mobile application. It covers functional requirement groups RF 1 to RF 8 and their specific requirements ERF.

It includes:

- Management of users, roles, and permissions.
- Mass import via CSV files.
- Mobile authentication and credential recovery.
- Management of environments, cohorts, responsibles, and shifts.
- Attendance registration via face and fingerprint.
- Control of unregistered personnel entry.
- Mobile configuration of alerts, language, palettes, and user parameters.
- IoT device failure alerts.
- Parameterization of delays and justifications.
- Attendance and absence histories.
- User change auditing.
- Upload, approval, rejection, and notification of justifications.
- Export of reports, analytical dashboard, and date-range queries.
- Management of courses and study plans.

Definitions

- *RF*: High-level functional requirement.
- *ERF*: Specific functional requirement derived from an RF.
- *Actor*: Person, system, or device that interacts with the software.
- *Precondition*: State that must be met before starting a requirement.
- *Postcondition*: Expected state upon successful completion of a requirement.
- *Business Rule*: Restriction or policy governing system behavior.
- *Acceptance Criterion*: Objective condition that allows a requirement to be declared fulfilled.
- *RBAC*: Role-Based Access Control.
- *Biometrics*: Physiological or behavioral measure used to identify or verify a person.

- *Biometric Template*: Encrypted mathematical representation of facial or fingerprint features, distinct from the raw image.
- *IoT*: Internet of Things; connected devices capable of generating telemetry or events.
- *Cohort (Ficha)*: Group, course, or operational academic unit associated with responsibles, shifts, and environments.
- *Shift (Jornada)*: Time slot or turn associated with academic or administrative activities.
- *Justification*: Documentary support presented to explain an absence, delay, or irregularity.
- *Audit*: Traceable record of who did what, when, from where, and on what data.

System Actors

Table 1

System Actors

Actor	Description	Main Interaction
General Administrator	User with broad configuration and management privileges	Manages users, roles, permissions, courses, parameters, and global reports
Academic Responsible	Instructor assigned to cohorts or environments	Manages attendance, justifications, and queries within their scope
Registered Personnel	Authorized school user	Consults their profile, marks attendance, and presents justifications
Unregistered Personnel	Visitor, contractor, or temporary person	Enters via supervised alternative registration
Mobile Application	Client used on mobile devices	Authentication, facial registration, fingerprint, alerts, configuration, and queries
Web Platform	Administrative and query interface	Master management, CSV import, reports, and auditing
IoT Devices	Connected sensors, controllers, or peripherals	Send state, failures, and operation events
Notification Service	Technical messaging component	Delivers push, email, or SMS according to configuration
Auditor or Quality	Supervision role	Reviews traceability, evidence, and regulatory compliance

Source. Own elaboration.

Premises and Restrictions

Premises

- Registered users possess unique credentials or a valid identity document.
- Mobile devices support a front camera and, optionally, a fingerprint sensor.
- The mobile application requires operating system permissions for camera, biometrics, notifications, and storage when applicable.
- A base catalog of courses, environments, cohorts, and shifts exists before critical attendance operation.
- Assigned responsibles have a current contractual or labor relationship with the school.

Restrictions

- Biometric data storage must comply with principles of minimization, security, consent, and defined retention.
- Authorization must be applied on the server; hiding menus in the interface is not sufficient security control.
- CSV import must mitigate risks of formula injection and personal data exposure.
- Reports must respect the principle of least privilege according to the assigned role and scope.
- Critical security or IoT failure alerts should not be completely disableable by the end user, unless an explicitly approved policy exists.
- Changes in roles, user status, and delay parameterization must be audited.

Transversal Acceptance Criteria

Every functional requirement described in this report must meet, at minimum, the following transversal criteria:

1. Input validation on both client and server.
2. Prior authentication when the requirement involves personal or administrative data.
3. Role and permission-based authorization, with denial by default.
4. Clear error messages, without leaking sensitive information.

5. Audit logging for creative, modificative, eliminatory, authentication, and status change operations.
6. Protection of personal and biometric data through encryption in transit and at rest.
7. Traceability between interface, API, database, and deployment evidence.
8. Unit, integration, and edge-case test cases associated with the requirement.
9. Deterministic behavior under slow networks, expired sessions, denied permissions, and inconsistent data.
10. Basic accessibility: legible contrast, clear labels, and keyboard navigation on web.

Functional Requirements

RF 1 User Management

Purpose: Administer the life cycle of digital identities in the system, including registration, authentication, roles, permissions, status, and information queries.

Platforms: Administrative web and mobile depending on the specific requirement.

Main Dependencies: RF 4.6, RF 5.2.

ERF 1.1 Register Users

- *Purpose:* Create a new user with personal data, initial credentials, and role relationship.
- *Platform:* Web.
- *Preconditions:* The authenticated operator possesses user creation permissions.
- *Minimum Inputs:* Identity document, document type, first names, last names, email, optional phone, initial role, and status.
- *Processing:* Validate formats, uniqueness of document and email, apply password policy or generate secure invitation, register audit, and link initial role.
- *Outputs:* Created user, unique identifier, success or detailed error message, audit event.
- *Business Rules:*

    - An identity document cannot be repeated within the same validity or document type.
    - Email must be unique for authentication, unless an approved contrary policy exists.
    - The user is born active only if the activation policy allows; otherwise, they remain pending activation.
- *Acceptance Criteria:*
    - The system prevents registering users with duplicate documents.
    - The system validates email and phone formats when mandatory.
    - The user is persisted with creation date and responsible operator.
    - An invitation or initial credential is sent via a secure channel.
- *Security and Privacy:*
    - Do not store passwords in plain text.
    - Minimize personal data in logs.
    - Register consent when processing sensitive data.
- *Edge Cases:*
    - Email with invalid domain.
    - Document with prohibited characters.
    - Concurrent registration attempt of the same document.
    - Email service failure during invitation.
- *Suggested Tests:*
    - Unit tests for field validation.
    - Integration tests against uniqueness constraints.
    - Edge case: two simultaneous requests with the same document.

ERF 1.1.1 Role Assignment

- *Purpose:* Link one or more functional roles to the user.
- *Platform:* Web.

- *Inputs:* User, role, optional validity date, optional reason.
- *Business Rules:*
    - Only users with permission can assign roles.
    - A user can have a primary role and secondary roles if the model allows.
    - Assignment must be reversible and audited.
- *Acceptance Criteria:*
    - The system shows available roles according to the current catalog.
    - Prevents assigning non-existent or inactive roles.
    - Registers operator, date, previous role, and new role.
- *Security:* Prevent privilege escalation through server-side validation of the operator's permission.
- *Edge Cases:* Assigning a role to a deactivated user, removing the last mandatory role, role change during an active session.

ERF 1.1.2 Permission Assignment in Platform and Web

- *Purpose:* Define technical and functional capabilities per role or user.
- *Platform:* Web and API.
- *Recommended Model:* RBAC with granular permissions, e.g., `user:create`, `attendance:view`, `iot:acknowledge`.
- *Business Rules:*
    - Denial by default.
    - Permissions must be evaluated in the API, not just in the interface.
    - The web and mobile platforms may share logical permissions, with different capabilities per channel.
- *Acceptance Criteria:*
    - A user without permission receives an error 403 or equivalent and does not visualize the sensitive action.
    - A user with permission executes the operation without client bypass.

    - Permission changes are reflected in a new session or token renewal.
- *Security:* Signed tokens, short expiration, revocation if role or critical permission changes.
- *Edge Cases:* Permission withdrawn during a long operation, outdated permission cache, role without assigned permissions.

ERF 1.2 Register Users via CSV Files

- *Purpose:* Allow mass import of users from a structured file.
- *Platform:* Web.
- *Inputs:* CSV file encoded in UTF-8, with mandatory header and defined delimiter.
- *Minimum Suggested Columns:*

  `document,document_type,first_names,last_names,email,phone,initial_role,status`
- *Processing:*
    - Validate structure, encoding, maximum size, and header.
    - Parse rows without executing formulas.
    - Generate a preliminary report of valid, duplicate, and error rows.
    - Import in a transactional batch or with a partial success report, according to policy.
- *Acceptance Criteria:*
    - The system rejects files with an incomplete header.
    - Shows errors by row number and field.
    - Prevents CSV formula injection in exportable fields.
    - Registers an import audit with total processed, successful, and failed counts.
- *Security:*
    - Sanitize values starting with `=`, `+`, `-`, `@`, tab, or carriage return.
    - Restrict upload to authorized users.

    - Store temporary file securely and delete it after processing.
- *Edge Cases:*
    - Empty file.
    - Poorly encoded accents.
    - Duplicate rows within the same file.
    - Very large file exceeding request time.
- *Suggested Tests:*
    - Test with malicious CSV formulas.
    - Test partial import and rollback.
    - Performance test with ten thousand rows.

ERF 1.3 Login

- *Purpose:* Authenticate the user in the mobile application.
- *Platform:* Web and Mobile.
- *Methods:* Email or username with password; optionally local biometric unlock of the device.
- *Business Rules:*
    - Temporarily block after N failed attempts.
    - Do not reveal if the user exists or the password is incorrect.
    - Require re-authentication for sensitive operations.
- *Acceptance Criteria:*
    - Valid credentials grant secure access and refresh tokens.
    - Invalid credentials show a generic message.
    - Session expires according to policy.
    - Local biometric unlock does not replace server-side authentication unless an approved design exists.
- *Security:*
    - Store tokens in keystore or keychain.

    - Refresh token rotation.
    - Optional device binding based on risk.
- *Edge Cases:* No connection, revoked token, device change, account deactivated during session.

ERF 1.4 Password Recovery

- *Purpose:* Allow secure credential resetting.
- *Platform:* Web and Mobile.
- *Flow:* Request recovery, issue single-use token, validate identity, allow new password.
- *Business Rules:*
    - Token with short expiration, e.g., fifteen to sixty minutes.
    - Single use.
    - Rate limiting by email, IP, and device.
    - Generic response if the email does not exist.
- *Acceptance Criteria:*
    - The user receives a link or code via a secure channel.
    - The system invalidates the token after use or expiration.
    - Upon password change, active sessions are revoked unless the policy allows the current one.
- *Security:* Do not send the new password by email; do not log tokens.
- *Edge Cases:* Unregistered email, reused token, user enumeration attempt, notification channel failure.

ERF 1.5 Password Change

- *Purpose:* Allow the authenticated user to modify their password.
- *Platform:* Web and Mobile.
- *Preconditions:* Valid session or re-authentication step.
- *Business Rules:*

    - Require current password or an additional factor.
    - Apply complexity policy.
    - Prevent reuse of recent passwords if the policy defines it.
- *Acceptance Criteria:*
    - Weak password is rejected.
    - Successful change generates audit and revocation of other sessions.
    - The user remains authenticated only if the policy allows.
- *Edge Cases:* Forgetting current password, locked account, simultaneous change on two devices.

ERF 1.6 Activate/Deactivate Users

- *Purpose:* Suspend or restore access without deleting history.
- *Platform:* Web.
- *Business Rules:*
    - Deactivated user cannot authenticate.
    - Active sessions must be revoked.
    - Attendance history, justifications, and auditing are preserved.
- *Acceptance Criteria:*
    - Status change is audited with reason and operator.
    - Login attempt by deactivated user is rejected.
    - Reactivation restores access according to current roles.
- *Edge Cases:* Deactivating one's own administrator account, deactivating a user with an open process, reactivation without valid roles.

ERF 1.7 Delete Users

- *Purpose:* Remove a user from the system respecting legal retention and traceability.
- *Platform:* Web.
- *Recommended Model:* Logical deletion or anonymization, not immediate physical erasure.

- *Business Rules:*
    - Only elevated roles can delete.
    - A reason must be registered.
    - If critical historical records exist, the user is anonymized but operational evidence is preserved.
- *Acceptance Criteria:*
    - The user disappears from active lists.
    - Cannot authenticate.
    - Sensitive personal data is anonymized or encrypted according to policy.
    - An irreversible audit of the event remains.
- *Edge Cases:* User with justifications in progress, user with assigned roles, erasure request (right to be forgotten) with legal exceptions.

ERF 1.8 User Information Query

- *Purpose:* Allow viewing profile data, status, roles, and assignments.
- *Platform:* Web and Mobile.
- *Business Rules:*
    - The user can query their own information.
    - Administrators and responsibles query according to authorized scope.
    - Sensitive fields are masked if no explicit permission exists.
- *Acceptance Criteria:*
    - The query shows updated data.
    - Does not expose other users' information without authorization.
    - Access to sensitive data is audited when applicable.
- *Edge Cases:* Incomplete profile, expired roles, request from an expired session.

RF 2 Environment Management

Purpose: Administer physical or logical spaces, academic cohorts, responsibles, and associated shifts.

Platforms: Primarily Web; mobile for queries according to role.

Main Dependencies: RF 1, RF 3, RF 8.

ERF 2.1 Register Environments or Classrooms

- *Purpose:* Create and maintain the catalog of environments where activities occur.
- *Platform:* Web.
- *Minimum Inputs:* Code, name, capacity, location, type, status.
- *Business Rules:*
    - Unique code.
    - Capacity greater than zero if physical.
    - Do not delete environment with active assignments; use inactivation.
- *Acceptance Criteria:*
    - The system validates code duplication.
    - Allows querying active and inactive environments according to permission.
    - Creation, editing, and inactivation are audited.
- *Edge Cases:* Environment without location, zero capacity, code change with associated history.

ERF 2.2 Register Cohorts or Courses

- *Purpose:* Define operational academic units linked to courses, periods, and responsibles.
- *Platform:* Web.
- *Minimum Inputs:* Cohort code, name, associated course, period, modality, capacity, status.
- *Business Rules:*
    - A cohort must be linked to a current course from the RF 8 catalog.
    - Cohort code must be unique within the academic period.

    - Cannot be activated without an assigned responsible if the policy requires it.
- *Acceptance Criteria:*
    - Successful cohort creation is visible to authorized responsibles.
    - Editing a cohort preserves history if critical data changes.
    - Inactivating a cohort prevents new assignments but preserves histories.
- *Edge Cases:* Duplicate cohort, deleted course, period change with previous attendees.

ERF 2.3 Assign Responsibles

- *Purpose:* Link authorized persons to the management of environments, cohorts, or shifts.
- *Platform:* Web.
- *Business Rules:*
    - The responsible must be an active user with a pertinent role.
    - Assignment can have a start-end validity.
    - A primary responsible and, optionally, substitutes must be allowed.
- *Acceptance Criteria:*
    - The system prevents assigning inactive users.
    - The assignment is reflected in query and operation permissions.
    - Assignment, removal, and validity change are audited.

ERF 2.3.1 Assign Cohorts

- *Purpose:* Relate responsibles with specific cohorts.
- *Platform:* Web.
- *Business Rules:*
    - A responsible only sees and operates assigned cohorts, unless they have a global role.
    - Assignment can be multiple.

    - Unjustified overlap of responsibilities must be controlled if the policy requires it.
- *Acceptance Criteria:*
    - Successful assignment enables actions on the cohort.
    - Immediate or scheduled removal revokes access according to validity.
- *Edge Cases:* Responsible withdrawn with pending justifications, circular assignment, cohort without responsible.

ERF 2.3.2 Assign Shifts

- *Purpose:* Link responsibles to time slots or turns.
- *Platform:* Web.
- *Inputs:* Responsible, shift, optional environment, optional cohort, validity.
- *Business Rules:*
    - A shift defines start, end, day, or recurring pattern.
    - Time zone must be validated.
    - Overlaps that generate ambiguity of responsibility are not permitted, unless an approved exception exists.
- *Acceptance Criteria:*
    - The system correctly calculates the active shift by date and time.
    - The assignment impacts attendance and delay reports.
- *Edge Cases:* Daylight saving time change, shift crossing midnight, responsible with multiple simultaneous shifts.

RF 3 Entry and Exit Records

Purpose: Capture entry and exit events of registered and unregistered personnel, with mobile biometric support and controlled alternatives.

Platforms: Primarily Mobile; web for supervision and auditing.

Main Dependencies: RF 1, RF 2, RF 4.5, RF 4.7, RF 6.

ERF 3.1 Register Entries and Exits

- *Purpose:* Create an attendance event with entry or exit direction.
- *Platform:* Mobile, Web, and API.
- *Minimum Inputs:* User or temporary credential, event type, timestamp, device, method, location or environment if applicable.
- *Business Rules:*
    - The same user cannot register two consecutive entries without an exit, unless an authorized correction is made.
    - The timestamp must use server time or reliable synchronization.
    - The event must be idempotent to network retries.
- *Acceptance Criteria:*
    - Successful registration returns confirmation and saves evidence.
    - Duplicate registration is detected and rejected or corrected according to policy.
    - The event is linked to a cohort, environment, or shift when applicable.
- *Security:* Sign mobile payload, validate device, prevent replay attacks.
- *Edge Cases:* No connection, altered device clock, abrupt location change, user deactivated during attempt.

ERF 3.1.1 Facial Registration

- *Purpose:* Identify or verify the user via facial recognition on mobile.
- *Platform:* Web and Mobile.
- *Flow:* Facial capture, liveness detection, template extraction, comparison with registered template, decision.
- *Business Rules:*
    - Requires consent and prior enrollment registration.
    - Must apply a configurable matching threshold.

    - If it fails, enables an alternate route: fingerprint, credential, or assisted registration.
- *Acceptance Criteria:*
    - Valid user is recognized within the approved threshold.
    - Basic spoofing with a photo or screen must be rejected by liveness mechanisms.
    - Raw images are not stored unnecessarily; encrypted templates and audit metadata are preserved.
- *Security and Privacy:*
    - Encryption of biometric templates.
    - Defined retention.
    - Prohibition of sharing templates for unauthorized purposes.
    - Registration of failed attempts.
- *Edge Cases:* Insufficient light, partially covered face, physiological changes, rooted device or emulator, sensor failure.

ERF 3.1.2 Alternative Registration (Fingerprint)

- *Purpose:* Use fingerprint as an alternative or complementary method (digitalPerson 4500).
- *Platform:* Web and Mobile.
- *Business Rules:*
    - Only available if the device and operating system support it.
    - Must respect the device's secure enclave when it exists.
    - Sensor failure enables an alternate method.
- *Acceptance Criteria:*
    - Valid fingerprint registers attendance.
    - Unregistered fingerprint generates a secure error and alternate option.

    - Raw fingerprint images are not stored outside the operating system if the platform offers a secure template.
- *Edge Cases:* Wet or injured finger, dirty sensor, device change, user with multiple registered fingers.

RF 4 System Configuration

Purpose: Administer mobile preferences, alerts, language, themes, user parameters, role changes, and delay or justification rules.

Platforms: Mobile and administrative web.

Main Dependencies: RF 1, RF 3, RF 5, RF 6, RF 7.

ERF 4.1 Configure Alerts

- *Purpose:* Allow the user to manage system notifications.
- *Platform:* Web and Mobile.
- *Alert Types:* Attendance, approved or rejected justification, IoT failure, role change, academic reminders, critical security alerts.
- *Business Rules:*
    - Critical security or compliance alerts may be non-disableable.
    - Configuration must sync between device and server if the user changes mobile devices.
- *Acceptance Criteria:*
    - The user activates or disables permitted categories.
    - The system respects operating system permissions.
    - Preferences persist after app restart.

ERF 4.1.1 Activate/Deactivate Alerts

- *Purpose:* Control reception by event type.
- *Business Rules:*
    - Deactivating does not suppress server-side audit records.
    - A secure default value must exist.

- *Acceptance Criteria:*
    - Immediate change reflected in the next notification.
    - Mandatory alerts cannot be deactivated from the end-user interface.
- *Edge Cases:* Notification permission denied by OS, user with multiple devices, conflicting synchronization.

ERF 4.2 Configure Languages

- *Purpose:* Allow selection of the interface language.
- *Platform:* Web and Mobile.
- *Minimum Suggested Languages:* Spanish, English, French, and Portuguese.
- *Business Rules:*
    - Automatic fallback to Spanish if a translation is missing.
    - Dates, numbers, and currency are formatted according to the person's locale.
- *Acceptance Criteria:*
    - Language change updates the interface without mandatory restart, or informs if a restart is required.
    - Error messages are also translated.
- *Edge Cases:* Unsupported locale, truncated text, mixture of languages due to missing resources.

ERF 4.3 Update Color Palettes

- *Purpose:* Apply visual themes and institutional palettes.
- *Platform:* Web and Mobile.
- *Business Rules:*
    - Must maintain accessible contrast.
    - Light and dark modes recommended.
    - Palette must not alter the semantics of states: success, warning, error.
- *Acceptance Criteria:*

    - The user selects a theme and it is applied immediately.
    - Critical components maintain legibility.
    - The preference persists.
- *Edge Cases:* Custom theme with low contrast, app update with incompatible palette.

ERF 4.4 User Parameter Update (Mobile)

- *Purpose:* Centralize personal user settings on mobile.
- *Parameters:* Language, theme, notifications, optional contact data, biometric enrollment, password change, privacy.
- *Business Rules:*
    - Sensitive changes require re-authentication.
    - Format and permissions must be validated.
- *Acceptance Criteria:*
    - Successful save confirms the change and audits if relevant.
    - Cancellation does not persist modifications.
- *Edge Cases:* Session expired during editing, synchronization conflict, camera permission denied during facial enrollment.

ERF 4.5 IoT Device Failure Alert Management

- *Purpose:* Supervise the operational status of connected devices.
- *Minimum Events:* Offline, low battery, sensor failing, tampering, invalid reading, reconnection.
- *Business Rules:*
    - Configurable thresholds per device type.
    - Escalation to the responsible person if not attended within a defined time.
    - Mandatory acknowledgment for critical events.
- *Acceptance Criteria:*
    - The system detects heartbeat loss.
    - Generates an alert with device, location, time, and severity.

    - Allows assigning a ticket or corrective action.
- *Security:* Mutual device-server authentication, credential rotation, network isolation.
- *Edge Cases:* Compromised device, burst of repeated events, false alarm due to maintenance.

ERF 4.6 Change Role of a User

- *Purpose:* Modify the role assigned to an existing user.
- *Platform:* Web.
- *Business Rules:*
    - Requires an authorized operator.
    - Must register reason and validity.
    - Can revoke sessions or force permission refresh.
- *Acceptance Criteria:*
    - The new role is applied according to an immediate or scheduled policy.
    - The user loses or gains access according to permissions.
    - A complete audit of the change remains.
- *Edge Cases:* Changing one's own role, non-existent role, user with multiple sessions, change during a critical process.

ERF 4.7 Delays and Justifications (Parameterization)

- *Purpose:* Configure rules to classify delays, absences, and the acceptance of justifications.
- *Suggested Parameters:* Tolerance minutes, marking deadline, type of absence, justification deadlines, accepted support types, approvers, notifications.
- *Business Rules:*
    - Parameters must be versioned and have a validity date.
    - Changes must not alter already closed histories, unless an authorized correction is made.

    - It must be defined whether the delay is calculated by shift, cohort, or environment.
- *Acceptance Criteria:*
    - The system correctly classifies attendance, delay, and absence according to current parameters.
    - Allows querying active parameters and their history.
    - Impacts RF 5 and RF 7 reports without inconsistencies.
- *Edge Cases:* Parameter change mid-day, shift crossing midnight, justification submitted past the deadline, inconsistent time zone.

RF 5 Generate Histories

Purpose: Consult and preserve antecedents of attendance, absence, and user changes.

Platforms: Mobile and Web.

Main Dependencies: RF 1, RF 2, RF 3, RF 4.7.

ERF 5.1 Attendance and Absence (Mobile) by Parameters

- *Purpose:* Consult attendance movements filtered by date, cohort, environment, instructor, or person.
- *Platform:* Mobile.
- *Minimum Filters:* Date range, cohort, environment, instructor, person, status, registration method.
- *Business Rules:*
    - The responsible only sees data within their scope.
    - Absence calculation uses RF 4.7 parameters.
    - Must support pagination and sorting.
- *Acceptance Criteria:*
    - The query returns results consistent with the database.
    - Combined filters work without exposing unauthorized data.

    - Detail of the event is shown: time, method, device, status, and associated justification if it exists.
- *Edge Cases:* Inverted date range, too many results, user without assignments, biometric data without confirmed match.

ERF 5.2 User Change History

- *Purpose:* Register a log of modifications to profile, roles, permissions, status, and credentials.
- *Platform:* Web and API.
- *Minimum Audit Fields:* Affected entity, identifier, operator, date/time, action, previous and new values, IP, device, reason.
- *Business Rules:*
    - History must be immutable or append-only.
    - Sensitive data is masked in non-privileged views.
    - Retention according to legal and operational policy.
- *Acceptance Criteria:*
    - Every relevant change generates a record.
    - The record allows reconstructing the user's timeline.
    - Only authorized roles consult the full history.
- *Edge Cases:* Simultaneous change by two administrators, mass CSV import, logical deletion, access from a compromised session.

RF 6 Justification Management

Purpose: Allow presenting, reviewing, approving, or rejecting supports that explain attendance irregularities.

Platforms: Mobile and Web.

Main Dependencies: RF 1, RF 3, RF 4.7, RF 5.

ERF 6.1 Upload Justification Supports

- *Purpose:* Upload a document or image that supports an absence or delay.

- *Platform:* Mobile and Web.
- *Inputs:* Associated attendance event, justification type, description, file.
- *Minimum Suggested Formats:* PDF, JPG, PNG.
- *Business Rules:*
    - Configurable maximum size.
    - Only events permitted by the deadline can be justified.
    - The file must be scanned for malware.
- *Acceptance Criteria:*
    - Successful upload associates support with the event.
    - Disallowed format is rejected with a clear message.
    - A digital fingerprint or hash of the file remains.
- *Security:* Encrypted storage, access control, secure deletion if applicable.
- *Edge Cases:* Corrupt file, filename with special characters, interrupted upload, sensitive document exposed in thumbnail.

ERF 6.2 Approval and Rejection

- *Purpose:* Allow the evaluator to decide on the justification.
- *Platform:* Web and Mobile according to role.
- *Suggested States:* Pending, under review, approved, rejected, closed.
- *Business Rules:*
    - Only designated approvers can resolve.
    - Rejection requires a mandatory comment.
    - Double resolution is not permitted without an audited annulment.
- *Acceptance Criteria:*
    - Approval updates the event status if the policy requires it.
    - Rejection notifies the requester.
    - Every decision is audited with approver, date, and reason.

- *Edge Cases:* Approver without permissions, justification already resolved, parameter change during review, appeal if it exists.

ERF 6.3 Automatic Notification of Result (A/R)

- *Purpose:* Automatically inform the user about approval or rejection.
- *Channels:* Mobile push, email, optional SMS.
- *Business Rules:*
    - Clear template without unnecessary sensitive data.
    - Retries if the channel fails.
    - Delivery record.
- *Acceptance Criteria:*
    - The user receives a notification after the decision.
    - The notification includes a secure link to the detail.
    - Delivery failure generates an operational alert and retry.
- *Edge Cases:* Notification disabled, full email, invalid number, duplicate sending due to retry.

RF 7 Advanced Visualization and Reports

Purpose: Provide analytical queries, exportation, and operational reports on attendance, delays, absences, and system activity.

Platforms: Primarily Web; mobile for reduced queries.

Main Dependencies: RF 2, RF 3, RF 4.7, RF 5, RF 6.

ERF 7.1 Export Report

- *Purpose:* Generate a downloadable file with filtered data.
- *Minimum Formats:* CSV, XLSX, PDF.
- *Business Rules:*
    - Large exports must be asynchronous.
    - The download link expires.
    - Masking is applied according to role.

    - CSV must mitigate formula injection.
- *Acceptance Criteria:*
    - The exported file matches the filters seen on screen.
    - Export audit is registered: user, filters, format, date.
    - Does not export data outside the authorized scope.
- *Edge Cases:* Empty dataset, timeouts, data sensitivity, repeated download, corrupt file.

ERF 7.2 Analytical Dashboard

- *Purpose:* Visualize key indicators of attendance, justifications, delays, IoT failures, and user activity.
- *Platform:* Web.
- *Suggested KPIs:* Attendance rate, delay rate, absences per cohort, pending justifications, approval/rejection, IoT devices with failure, active users.
- *Business Rules:*
    - Global filters by period, environment, cohort, and instructor.
    - Drill-down to detail.
    - Periodic or on-demand updates.
- *Acceptance Criteria:*
    - Indicators calculate correctly according to current parameters.
    - Acceptable loading times for expected volume.
    - Access restricted by role.
- *Edge Cases:* Null data, long ranges, concurrency of heavy queries, outdated cache.

ERF 7.3 Date-Range Reports

- *Purpose:* Consult information bounded temporarily.
- *Business Rules:*
    - Start date not later than end date.
    - Configurable maximum range limit.

    - Explicit time zone.
    - Days are inclusive or exclusive according to documented definition.
- *Acceptance Criteria:*
    - The report returns only events within the range.
    - Range errors are shown clearly.
    - Midnight crossovers are calculated correctly.
- *Edge Cases:* Daylight saving time, single-day range, future date, device time zone different from server.

ERF 7.4 Query of Delays and Absences by Parameters

- *Purpose:* List events classified as delay or absence according to filters.
- *Filters:* Date, cohort, environment, instructor, person, event type, justification status.
- *Business Rules:*
    - Uses RF 4.7 parameters.
    - Must show the cause of classification: marking time, tolerance, absence of exit, etc.
- *Acceptance Criteria:*
    - The query is consistent with RF 5 histories.
    - Allows exporting results.
    - Respects the responsible's scope.
- *Edge Cases:* Event without assigned shift, approved justification that reverses absence, retroactive parameter change.

RF 8 School Management

Purpose: Administer the catalog of courses and study plans associated with subjects and academic cohorts.

Platforms: Web.

Main Dependencies: RF 2, RF 5, RF 7.

ERF 8.1 Add and Delete Courses

- *Purpose:* Maintain the master catalog of courses offered by the school.
- *Minimum Inputs:* Code, name, description, duration, modality, status.
- *Business Rules:*
    - Unique code.
    - Logical deletion if cohorts, plans, or histories are associated.
    - Inactivating a course prevents new cohorts but preserves previous reports.
- *Acceptance Criteria:*
    - Successful course creation enables it for assignment in cohorts.
    - Editing a course preserves traceability if critical data changes.
    - Deleting or inactivating requires confirmation and audit.
- *Edge Cases:* Course with active cohorts, code duplication, modality change with assigned students.

ERF 8.2 Study Plan of Subjects

- *Purpose:* Define the academic structure of subjects, hours, sequence, and prerequisites.
- *Minimum Inputs:* Course, subject, code, hourly intensity, order, optional prerequisites, competencies, validity.
- *Business Rules:*
    - The plan must be versioned.
    - A cohort is associated with a current version of the plan.
    - Deleting a plan with active cohorts is not permitted; the version is inactivated or closed.
- *Acceptance Criteria:*
    - Publishing a plan makes it available for cohorts.
    - Consulting a plan shows subjects and hours correctly.
    - Version changes do not alter closed histories.

- *Edge Cases:* Circular prerequisite, subject without hours, plan published without review, plan change mid-period.

Requirements Traceability Matrix

Table 2

Requirements Traceability Matrix

ID	Name	Platform	Depends on	Priority
ERF 1.1	Register users	Web	RF 4.6	High
ERF 1.1.1	Role assignment	Web	ERF 1.1	High
ERF 1.1.2	Permission assignment	Web/API	ERF 1.1.1	High
ERF 1.2	Mass CSV registration	Web	ERF 1.1	Medium
ERF 1.3	Mobile login	Mobile	ERF 1.1	High
ERF 1.4	Password recovery	Web/Mobile	ERF 1.3	High
ERF 1.5	Password change	Web/Mobile	ERF 1.3	High
ERF 1.6	Activate or deactivate users	Web	ERF 1.1	High
ERF 1.7	Delete users	Web	ERF 1.6	Medium
ERF 1.8	User information query	Web/Mobile	ERF 1.1	Medium
ERF 2.1	Register environments	Web	RF 1	Medium
ERF 2.2	Register cohorts or courses	Web	ERF 8.1	High
ERF 2.3	Assign responsibles	Web	ERF 1.1	High
ERF 2.3.1	Assign cohorts	Web	ERF 2.2	High
ERF 2.3.2	Assign shifts	Web	ERF 2.1	High
ERF 3.1	Register entries and exits	Mobile/API	ERF 2.3	Critical
ERF 3.1.1	Mobile facial registration	Mobile	ERF 3.1	Critical
ERF 3.1.2	Fingerprint alternate registration	Mobile	ERF 3.1	High
ERF 3.2	Unregistered personnel control	Mobile/Web	ERF 3.1	High
ERF 3.2.1	Temporary alternative registration	Mobile/Web	ERF 3.2	High
ERF 4.1	Configure mobile alerts	Mobile	ERF 1.3	Medium
ERF 4.1.1	Activate or deactivate alerts	Mobile	ERF 4.1	Medium
ERF 4.1.2	Change tone	Mobile	ERF 4.1	Low
ERF 4.2	Configure languages	Mobile	ERF 1.3	Medium
ERF 4.3	Palette updates	Mobile	ERF 1.3	Low
ERF 4.4	User parameters	Mobile	ERF 1.1	Medium

ID	Name	Platform	Depends on	Priority
ERF 4.5	IoT failure alerts	Web/Mobile	IoT Infrastructure	High
ERF 4.6	Change role	Web	ERF 1.1.1	High
ERF 4.7	Delay parameterization	Web	ERF 2.3.2	Critical
ERF 5.1	Mobile attendance histories	Mobile	ERF 3.1	High
ERF 5.2	User change history	Web/API	ERF 1.1	High
ERF 6.1	Support upload	Mobile/Web	ERF 3.1	High
ERF 6.2	Approval and rejection	Web/Mobile	ERF 6.1	High
ERF 6.3	Result notification	Mobile/Web	ERF 6.2	Medium
ERF 7.1	Export report	Web	ERF 5.1	Medium
ERF 7.2	Analytical dashboard	Web	ERF 5.1	Medium
ERF 7.3	Date-range reports	Web	ERF 5.1	High
ERF 7.4	Query delays and absences	Web/Mobile	ERF 4.7	High
ERF 8.1	Add or delete courses	Web	RF 2	Medium
ERF 8.2	Study plan	Web	ERF 8.1	Medium

Source. Own elaboration.

Derived Non-Functional Requirements

Although the original statement focuses on functional requirements, the following non-functional requirements are necessary to bring the system to production level.

Table 3

Derived Non-Functional Requirements

Code	Category	Requirement	Verifiable Criterion
NFR-SEG-01	Security	Robust authentication and authorization	Signed tokens, short expiration, server-side RBAC
NFR-SEG-02	Security	Protection against injection and XSS	Input validation, escaping, CSP when applicable
NFR-PRIV-01	Privacy	Secure biometric data processing	Encrypted templates, consent, defined retention
NFR-PRIV-02	Privacy	Minimization of personal data in logs	Masking of emails, documents, and tokens
NFR-PERF-01	Performance	Mobile login	P95 less than or equal to three seconds on stable network

Code	Category	Requirement	Verifiable Criterion
NFR-PERF-02	Performance	Attendance registration	Local or server confirmation in less than five seconds
NFR-PERF-03	Performance	History queries	Pagination and acceptable response time up to defined volume
NFR-AVL-01	Availability	Critical attendance service	Agreed availability target, e.g., 99.5 percent monthly
NFR-USU-01	Usability	Clear mobile flows	Less than five steps to mark attendance with registered biometrics
NFR-ACC-01	Accessibility	Contrast and navigation	Basic WCAG 2.2 compliance for web interface (World Wide Web Consortium, 2023)
NFR-MNT-01	Maintainability	Modularity	Each RF implementable as a module with independent tests
NFR-PORT-01	Portability	Mobile support	Android and iOS according to agreed minimum versions
NFR-AUD-01	Audit	Traceability	All critical changes generate an immutable log
NFR-IOT-01	IoT Reliability	Failure detection	Heartbeat and alert in maximum defined interval

Source. Own elaboration.

Identified Technical and Business Risks

Table 4

Identified Technical and Business Risks

Risk	Impact	Probability	Mitigation
False positive in facial registration	Unauthorized access or incorrect attendance	Medium	Liveness, configurable threshold, audit, alternate method
Biometric false negative	Denial of service to legitimate user	Medium-High	Fingerprint, credential, assisted registration, operational support
Data exposure in CSV	Privacy violation	Medium	Sanitization, access control, encryption, temporary retention
Privilege escalation by roles	Administrative compromise	Low-Medium	Server-side RBAC, segregation of duties, audit
False IoT alerts	Operation fatigue	High	Thresholds, duplicate suppression, scheduled maintenance
Reports with out-of-scope data	Information leak	Medium	Filters by responsible, authorization tests

Risk	Impact	Probability	Mitigation
Retroactive parameter changes	Historical inconsistency	Medium	Parameter versioning, period closing, audit
Lack of connection on mobile	Loss of attendance record	Medium	Secure local queue, idempotent synchronization, reliable timestamp

Source. Own elaboration.

Verification and Validation Plan

Static Verification

- Review of this report by product, development, QA, security, and privacy.
- Consistency check between RF, ERF, roles, platforms, and dependencies.
- Validation that each requirement has a measurable acceptance criterion.

Unit Tests

- Personal field validators.
- Authentication and recovery services.
- Delay calculation according to parameters.
- CSV parsing and sanitization.
- RBAC and permission rules.

Integration Tests

- User registration with role and permission assignment.
- CSV import with mass creation and error report.
- Mobile login with token issuance and revocation.
- Facial or fingerprint registration linked to attendance event.
- Justification upload and status change.
- IoT failure generation and notification.

End-to-End Tests

- Complete flow: create user, assign role, import cohort, assign responsible, mark attendance, justify delay, approve justification, export report.
- Unregistered visitor flow: temporary entry, stay, exit, and closure.

- Role change flow with session revocation and permission update.

Security Tests

- User enumeration attempts in password recovery.
- Reuse of recovery tokens.
- Formula injection in exported CSV.
- Unauthorized horizontal and vertical access in histories and reports.
- Basic spoofing in facial registration, if technology allows evaluation.
- Review of biometric data storage and transmission according to OWASP ASVS (OWASP Foundation, 2021).

Performance Tests

- Concurrent load on mobile login.
- High volume of attendance events per shift.
- Dashboard queries with wide ranges.
- Asynchronous export of large reports.

User Validation

- UAT with administrators, academic responsibles, and operational personnel.
- Verification of mobile usability in real lighting, network, and device conditions.
- Confirmation that reports match business expectations.

Security and Privacy Considerations

Biometric Data

Biometric data are sensitive categories. The system must:

- Obtain informed consent when applicable.
- Store encrypted templates, not raw images unless technically justified and approved.
- Limit access to templates through service segregation.
- Define secure retention and deletion upon user departure or consent revocation.
- Register failed biometric authentication attempts without exposing sensitive data in logs.

- Evaluate risk of algorithmic bias and false negatives due to physical or environmental conditions.

Authentication and Sessions

- Strong hashing for passwords, e.g., Argon2, bcrypt, or scrypt according to adopted standard.
- MFA for critical roles if risk justifies it.
- Session revocation upon password, role, or status change.
- Protection against brute force and credential stuffing.

Import and Export

- Validate real MIME type, not just extension.
- Scan files for malware.
- Prevent CSV injection by prepending a secure character to risk fields.
- Limit report downloads to authorized users.
- Register export audit with used filters.

IoT

- Unique credentials per device.
- Periodic rotation.
- Encrypted communication.
- Network segmentation.
- Monitoring of anomalies and vulnerable firmware.

Annexes

Annex A. Minimum Operational Dictionary

Table 5

Annex A. Minimum Operational Dictionary

Term	Operational Definition
User	Natural person with a digital identity in the system
Role	Set of responsibilities grouping permissions

Term	Operational Definition
Permission	Technical capability to execute an action
Environment	Physical or logical space where activity occurs
Cohort	Academic or operational group associated with course, period, and responsibles
Shift	Time slot or turn of academic operation
Attendance	Valid record of presence within defined parameters
Delay	Presence outside configured tolerance
Absence	Unjustified or unregistered absence according to current rule
Justification	Documentary support explaining an irregularity
IoT Device	Connected element generating telemetry or events
Audit	Traceable record of actions on the system

Source. Own elaboration.

Annex B. Recommended Minimum Structure for CSV Import

Suggested header:

```
document,document_type,first_names,last_names,email,phone,initial_role,status
```

Rules:

- UTF-8 encoding.
- Comma or semicolon delimiter according to configuration.
- First row mandatory as header.
- Text fields in quotes if they contain delimiters.
- Dates in ISO 8601 format when applicable.
- Empty values allowed only in optional fields.
- Any field starting with equal, plus, minus, at, tab, or carriage return must be sanitized before exporting again.

Annex C. Example of Minimum RBAC Matrix

Table 6

Annex C. Example of Minimum RBAC Matrix

Action	Administrator	Academic Responsible	Registered Personnel	Temporary Visitor
Create user	Yes	No	No	No
Assign role	Yes	No	No	No
View own attendance	Yes	Yes if assigned	Yes	No
Mark attendance	N/A	Yes	Yes	Yes temporary
Approve justification	Yes	Yes if assigned	No	No
Export global report	Yes	No	No	No
Configure IoT	Yes	No	No	No
Change own password	Yes	Yes	Yes	No

Source. Own elaboration.

Note: This matrix is illustrative. The definitive matrix must be approved by security, product, and regulatory compliance.

Annex D. Suggested States for Justifications

Table 7

Annex D. Suggested States for Justifications

State	Description	Permitted Transitions
Pending	Received and awaiting review	Under review, rejected by deadline
Under review	Under evaluation by approver	Approved, rejected
Approved	Accepted and produces operational effect	Closed, authorized reopening
Rejected	Not accepted with reason	Resubmission if deadline allows
Closed	Process finished	Reopening only with special authorization

Source. Own elaboration.

Conclusions

This report transforms the initial list of functional requirements into a verifiable technical specification. Each RF and ERF was broken down with purpose, platform, rules, acceptance criteria, security, edge cases, and associated tests. This structure allows for reducing ambiguity, aligning development and QA, protecting sensitive data, and sustaining traceability for audits.

The most critical points of the system are: secure management of roles and permissions, reliable biometric registration, control of unregistered personnel, consistent parameterization of delays and justifications, and reports that respect the scope of the responsible party. Ignoring these aspects can lead to false attendance, data exposure, historical inconsistencies, or operational dysfunction.

For production implementation, it is recommended to validate this report with product, security, privacy, quality, and key user areas before freezing the scope. Subsequently, each ERF must be traced to epics, user stories, test cases, commits, pipelines, and deployment evidence.

Author's Note. Jonas is the author and technical responsible for this document. Correspondence related to this report may be directed to jonas@consultoria.example. The author declares the absence of conflicts of interest and external funding for the preparation of this document.

References

American Psychological Association. (2020). *Publication manual of the American Psychological Association* (7th ed.). https://doi.org/10.1037/0000165-000

International Organization for Standardization, International Electrotechnical Commission, & Institute of Electrical and Electronics Engineers. (2018). *Systems and software engineering — Life cycle processes — Requirements engineering* (ISO/IEC/IEEE 29148:2018). https://www.iso.org/standard/72089.html

OWASP Foundation. (2021). *OWASP Application Security Verification Standard 4.0*. https://owasp.org/www-project-application-security-verification-standard/

World Wide Web Consortium. (2023). *Web Content Accessibility Guidelines (WCAG) 2.2*. https://www.w3.org/TR/WCAG22/